

Vulnerability Audit and Assessment – Results and Executive Summary

Methodology

1. Information gathering: Research on human and physical assets was attempted and network scans were undertaken using 'nslookup' and 'traceroute' and results analysed;
2. Automated vulnerability scans were performed using OWASP ZAP and Wapiti3;
3. Manual vulnerability testing was conducted to test for the presence of the 2 sets of vulnerabilities reported by the automated scans ('false negative' tests), as well as the presence of two suspected - but not reported - vulnerabilities ('false positive' tests);
4. Results were analysed, compared to baseline assessment, and conclusions made and documented in a report.

Summary of data

Information gathering

Research on human and physical assets were unfortunately unsuccessful and no information was found in this regard. Further investigations or requests for this information would allow for a more comprehensive review of cross-business security mitigations.

The nslookup network scan revealed that ginandjuice.shop has two corresponding IP addresses, which suggests that one server is used as a load-balancer (see Appendix 10).

The traceroute network scan showed a number of intermediate routers that did not respond to traceroute packets (see Appendix 11). This could suggest that firewall configurations are functioning, however this requires further investigation to confirm.

Vulnerability scans

OWASP ZAP scan results:

Alert type	Count	Risk level
Vulnerable JSLibrary	1	High
Content Security Policy (CSP) Header Not Set	35	Medium
Cookie No HttpOnly Flag	174	Low
Cookie Without Secure Flag	87	Low
Cookie with SameSite Attribute None	88	Low
Cookie without SameSite Attribute	88	Low
Strict-Transport-Security Header Not Set	85	Low
X-Content-Type-Options Header Missing	80	Low
Information Disclosure - Suspicious Comments*	27	informational

**a manual scan revealed that the comments pertained to a vulnerability that could cause the site to crash, suggesting a DOS vulnerability – as such, the risk level was later raised to 'Medium'.*

Wapiti3 scan results:

Alert type	Count	Risk level
Content Security Policy (CSP) Header Not Set	1	Not given
X-XSS-Protection is not set in HTTP security header	3	Not given
Cookie No HttpOnly Flag	2	Not given
Cookie Without Secure Flag	1	Not given

Manual vulnerability test results:

Vulnerability	Comments
Information Disclosure - Suspicious Comments	False negative check - confirmed as vulnerability
Vulnerable JSLibrary	False negative check - confirmed as vulnerability
Content Security Policy (CSP) Header Not Set	False negative check - confirmed as vulnerability
Cookie No HttpOnly Flag	False negative check - confirmed as vulnerability
Cookie Without Secure Flag	False negative check - confirmed as vulnerability
Cookie with SameSite Attribute None	False negative check - confirmed as vulnerability
Cookie without SameSite Attribute	False negative check - confirmed as vulnerability
Strict-Transport-Security Header Not Set	False negative check - confirmed as vulnerability
X-Content-Type-Options Header Missing	False negative check - confirmed as vulnerability
X-XSS-Protection is not set in HTTP security header	False negative check - confirmed as false negative*
SQL injection vulnerability	False positive check - confirmed as vulnerability
XXS possible through JavaScript injection	False positive check - confirmed as non-vulnerability

** Further research into the X-XSS-Protection attribute setting showed that this feature is no longer recommended and can even cause vulnerabilities through its*

continued use (Mozilla, 2025); subsequently, this was omitted from the final list of verified vulnerabilities.

Final list of verified vulnerabilities:

Vulnerability	Risk level
Vulnerable JSLibrary	High
SQL injection vulnerability	High (NIST, 2024)
Information Disclosure - Suspicious Comments	Medium (NIST, 2024)
Content Security Policy (CSP) Header Not Set	Medium
Cookie No HttpOnly Flag	Low
Cookie Without Secure Flag	Low
Cookie with SameSite Attribute None	Low
Cookie without SameSite Attribute	Low
Strict-Transport-Security Header Not Set	Low
X-Content-Type-Options Header Missing	Low

The final list of verified vulnerabilities has been assessed according to risk level reported by original scan (if available). Where not available, the risk scores have been obtained with reference to the Common Vulnerability Scoring System (CVSS) (NIST, 2024). These risks have, however, been reassessed in the ‘recommendations’ section according to impact to business.

Comparison with baseline assessment

In the baseline assessment, many of the verified vulnerabilities were discussed as being prevalent in JavaScript-based web applications. The following vulnerabilities – identified by the scans - were referenced as ‘security misconfigurations’ in the baseline assessment:

- Cookie No HttpOnly Flag
- Cookie Without Secure Flag
- Cookie with SameSite Attribute None
- Cookie without SameSite Attribute
- Strict-Transport-Security Header Not Set
- X-Content-Type-Options Header Missing
- Content Security Policy (CSP) Header Not Set

Although outdated JavaScript libraries were identified in the baseline assessment in relation to prototype pollution attacks, the vulnerable, out-dated Angular.js software - used in parts of the website contains a vulnerability that, if exploited, can cause a

Regular Expression Denial of Service (ReDOS) attack (NIST, 2025), which would stop the functioning of the website and halt functionality until rectified.

The Information Disclosure - Suspicious Comments vulnerability would fall under the 'Insecure Design' header from the baseline assessment; the comments refer to a feature of a software component used to construct many of the webpages ('React'). Within the comments (see Appendix 2), lines of code are discussed that reveal where software errors will not be handled (Facebook Open Source, 2025) – potentially allowing an attacker to crash the software, effectively causing a Denial of Service (DOS) attack.

The SQL injection vulnerability was not specifically referenced in the baseline assessment but falls under the 'Injection' header. Such an attack can put sensitive, database-stored customer data, such as email and physical addresses, at risk of theft from cyber criminals. If exploited, this vulnerability, together with the 7 security misconfigurations listed above, would count as a very serious and direct General Data Protection Regulation (GDPR) breach, and could result in a substantial fine that could make the business unviable (Data Protection Act, 2018; Suorsa & Helo, 2024).

Comparisons against PCI-DSS and GDPR guidelines

PCI-DSS:

As mentioned in the baseline assessment, ginandjuice.shop must conform to GDPR (Data Protection Act, 2018) and, as an ecommerce site, its processing of data should also be driven by the Payment Card Industry Data Security Standard (PCI DSS) (PCI Security Standards Council, 2024). The website in question shows partial compliance with these 2 sets of standards.

The following table maps the identified security vulnerabilities with the GDPR Articles and PCI DSS requirements that have been breached:

Security vulnerability	GDPR Article breached (Data Protection Act, 2018)	PCI DSS requirement breached (PCI Security Standards Council, 2024)
Vulnerable JavaScript library	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure. Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software. 6.3.2 An inventory of bespoke and custom software, and third-party software 6.3.3 components incorporated into bespoke and custom software is maintained to facilitate vulnerability and patch management. All system components are protected from known vulnerabilities by installing applicable security patches/updates as follows: Patches/updates for critical vulnerabilities (identified according to the risk ranking process at Requirement 6.3.1) are installed within one month of release. All other applicable security patches/updates are installed within an appropriate time frame as determined by the entity's assessment of the criticality of the risk to the environment as identified according to the risk ranking process at Requirement 6.3.1. 6.4 Public-facing web applications are protected against attacks. 6.5 Changes to all system components are managed securely. 12.3.4 Hardware and software technologies in use are reviewed at least once every 12 months.

Security vulnerability	GDPR Article breached (Data Protection Act, 2018)	PCI DSS requirement breached (PCI Security Standards Council, 2024)
SQL injection	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure.	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software. 6.4 Public-facing web applications are protected against attacks.
Information Disclosure - Suspicious Comments	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure.	6.2.3 bespoke and custom software is to be reviewed prior to being released into production or to customers to identify and correct potential coding vulnerabilities.
Cookie No HttpOnly Flag	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure. Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software.

Security vulnerability	GDPR Article breached (Data Protection Act, 2018)	PCI DSS requirement breached (PCI Security Standards Council, 2024)
Content Security Policy (CSP) Header Not Set	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure.” Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software. 6.4 Public-facing web applications are protected against attacks. 6.4.3 All payment page scripts that are loaded and executed in the consumer’s browser are managed as follows: A method is implemented to confirm that each script is authorized. A method is implemented to assure the integrity of each script. An inventory of all scripts is maintained with written business or technical justification as to why each is necessary. 6.4.3.a Examine policies and procedures to verify that processes are defined for managing all payment page scripts that are loaded and executed in the consumer’s browser, in accordance with all elements specified in this requirement.
Strict-Transport-Security Header Not Set	Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	4.2.1 Strong cryptography and security protocols are implemented as follows to safeguard PAN during transmission over open, public networks: Only trusted keys and certificates are accepted. Certificates used to safeguard PAN during <i>transmission over open, public networks</i> are confirmed as valid and are not expired or revoked. <i>This bullet is a best practice until its effective date; refer to applicability notes below for details.</i> The protocol in use supports only secure versions or configurations and does not support fallback to, or use of insecure versions, algorithms, key sizes, or implementations. The encryption strength is appropriate for the encryption methodology in use.

Security vulnerability	GDPR Article breached (Data Protection Act, 2018)	PCI DSS requirement breached (PCI Security Standards Council, 2024)
Cookie without secure flag	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure. Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software. 4.2 PAN is protected with strong cryptography during transmission 4.2.1 Strong cryptography and security protocols are implemented as follows to safeguard PAN during transmission over open, public networks: Only trusted keys and certificates are accepted. Certificates used to safeguard PAN during <i>transmission over open, public networks are confirmed as valid and are not expired or revoked. This bullet is a best practice until its effective date; refer to applicability notes below for details.</i> The protocol in use supports only secure versions or configurations and does not support fallback to, or use of insecure versions, algorithms, key sizes, or implementations. The encryption strength is appropriate for the encryption methodology in use.
X-Content-Type-Options Header Missing	Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software.

Security vulnerability	GDPR Article breached (Data Protection Act, 2018)	PCI DSS requirement breached (PCI Security Standards Council, 2024)
Cookie with SameSite Attribute None	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure. Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software.
Cookie without SameSite Attribute	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure. Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software.

Despite numerous GDPR and PCI DSS requirements breaches, ginandjuice.shop shows partial compliance:

Security practice	GDPR compliance (Data Protection Act, 2018)	PCI DSS compliance (PCI Security Standards Council, 2024)
Input sanitisation: XSS protected against by blocking tags (<>) (see Appendix 7)	Article 5: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measure. Article 25: implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects. Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk.	6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks 6.4 Public-facing web applications are protected against attacks. Defined Approach Requirements Defined Approach Testing Procedures Purpose Public-facing web applications are those that are available to the public (not only for internal use).

Security practice	GDPR compliance (Data Protection Act, 2018)	PCI DSS compliance (PCI Security Standards Council, 2024)
Authentication: password-protected customer logins (see Appendix 8)	Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk. NB To make the website fully compliant with this article, customer authentication should be further secured by multi-factor authentication (MFA) (National Cyber Security Centre, N.D.).	8.3 Strong authentication for users and administrators is established and managed. 8.3.1 All user access to system components for users and administrators is authenticated via at least one of the following authentication factors: Something you know, such as a password or passphrase. Something you have, such as a token device or smart card. Something you are, such as a biometric element. 8.3.6 ...passwords used for customer logins adhere to complexity requirements (minimum length, inclusion of alphanumeric characters).

Security practice	GDPR compliance (Data Protection Act, 2018)	PCI DSS compliance (PCI Security Standards Council, 2024)
Secure data transfer-ence: secure cookies being used in request and response cookies, and HttpOnly flags being set for request cookies (see Appendix 9).	Article 32: Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk.	.2.1 Strong cryptography and security protocols are implemented as follows to safeguard PAN during transmission over open, public networks: Only trusted keys and certificates are accepted. Certificates used to safeguard PAN during transmission over open, public networks are confirmed as valid and are not expired or revoked. This bullet is a best practice until its effective date; refer to applicability notes below for details. The protocol in use supports only secure versions or configurations and does not support fallback to, or use of insecure versions, algorithms, key sizes, or implementations. The encryption strength is appropriate for the encryption methodology in use.

Summary of Recommendations

Before recommending mitigations, the identified security vulnerabilities have been ranked according to their business impact. An important factor in assessing this impact is the potential fines faced due to GDPR breaches. Figure 1 details a ranking of cases of historic security failures according to the size of subsequent fines imposed.

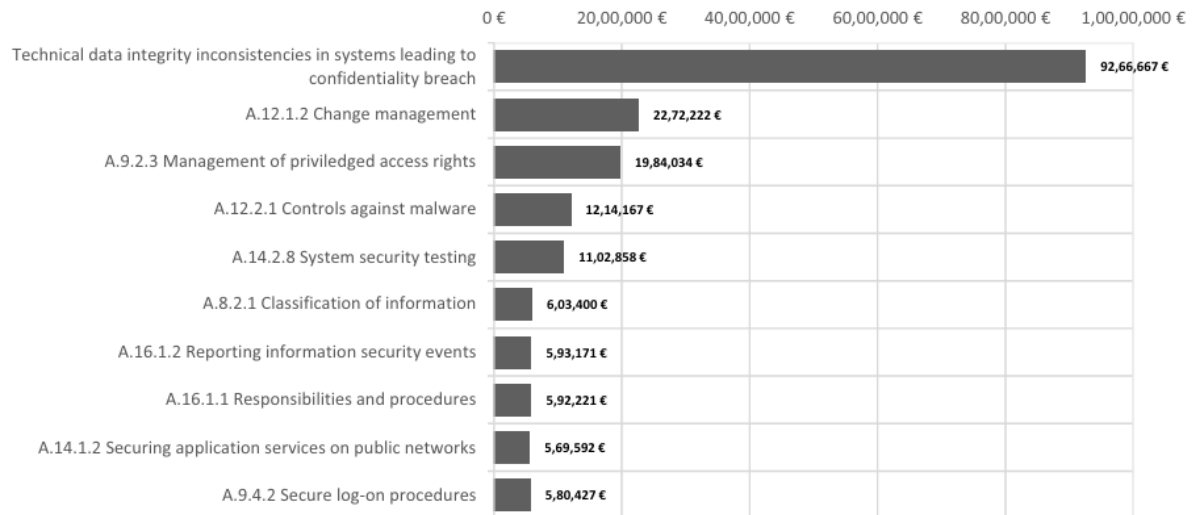


Figure 1: Top 10 most expensive (in terms of GDPR penalty cases) information security failures corresponding to ISO 27001 controls (Suorsa & Helo, 2024, p.296).

This data has been used to prioritise the mitigations of security vulnerabilities identified in this report (see Figure 2).

Ranking	Identified software vulnerability	ISO 27001 controls (International Organization for Standardization, 2013)
1	Content Security Policy (CSP) Header Not Set Cookie No HttpOnly Flag Cookie Without Secure Flag Cookie with SameSite Attribute None Cookie without SameSite Attribute Strict-Transport-Security Header Not Set X-Content-Type-Options Header Missing	Technical data integrity inconsistencies in systems leading to confidentiality breach Technical data integrity inconsistencies in systems leading to confidentiality breach Technical data integrity inconsistencies in systems leading to confidentiality breach Technical data integrity inconsistencies in systems leading to confidentiality breach Technical data integrity inconsistencies in systems leading to confidentiality breach Technical data integrity inconsistencies in systems leading to confidentiality breach Technical data integrity inconsistencies in systems leading to confidentiality breach
2	SQL injection vulnerability	System security testing
3	Vulnerable JS Library Information Disclosure - Suspicious Comments	Responsibilities and procedures

Figure 2: Software vulnerabilities that could result in data theft or unlawful processing, ranked highest to lowest risk to business, based on potential GDPR penalties (Suorsa & Helo, 2024).

Figure 3 displays the final verified list of security vulnerabilities ranked in order of mitigation priority according to financial and operational factors.

Ranking	Identified software vulnerability	Reason for ranking position
1	Content Security Policy (CSP) Header Not Set Cookie No HttpOnly Flag Cookie Without Secure Flag Cookie with SameSite Attribute None Cookie without SameSite Attribute Strict-Transport-Security Header Not Set X-Content-Type-Options Header Missing	Leaves customer data vulnerable and can lead to heavy fine Leaves customer data vulnerable and can lead to heavy fine Leaves customer data vulnerable and can lead to heavy fine Leaves customer data vulnerable and can lead to heavy fine Leaves customer data vulnerable and can lead to heavy fine Leaves customer data vulnerable and can lead to heavy fine Leaves customer data vulnerable and can lead to heavy fine
2	SQL injection vulnerability	Leaves customer data vulnerable and can lead to lower fine
3	Vulnerable JS Library Information Disclosure - Suspicious Comments	Could lead to DOS attack which would halt online purchases Displays sub-standard responsibilities and procedures which can lead to lower fine

Figure 3: All identified vulnerabilities ranked from highest to lowest risk to business.

The following recommendations outline the mitigations to the identified security vulnerabilities, in order of highest to lowest risk to business:

Vulnerability	Solution
Content Security Policy (CSP) Header Not Set	Ensure the Content Security Policy header is set in all servers (main and load-balancer) (Checkmarx, 2025a)
Cookie No HttpOnly Flag	The HTTPOnly flag should be set by all cookies protects against cross-site scripting (XSS) attacks as attackers can no longer generate scripts that will steal the session cookie (OWASP, 2025a)
Cookie Without Secure Flag	Cookies sending sensitive data should have a 'secure' flag set (OWASP, 2025b)
Cookie with SameSite Attribute None Cookie without SameSite Attribute	The 'same-site' cookie attribute should not be set to 'None' and should instead be set to 'strict' for all cookies to best prevent cross-site request forgery, XSS, and timing attacks (HTTP Working Group, 2016)
Strict-Transport-Security Header Not Set	Strict Transport Security header should be set as part of an opt-in security measure (OWASP, 2025c)
X-Content-Type-Options Header Missing	The Anti-MIME-Sniffing header X-Content-Type-Options should be set to 'nosniff' (Microsoft, 2016)
SQL injection vulnerability	SQL injections can be mitigated against by ensuring user input is sanitised on both the client and server side (Loonycorn, 2017), while using prepared statements secures the query before user-supplied data is provided, meaning that additional queries cannot be added after the SELECT statement if the user escapes the original query and begins anew (Hoffman, 2024)
Vulnerable JS Library	The use of Angular.js 1.7.7 should be upgraded to Angular 19.2.0 – the latest version of Angular (CheckMarx, 2025b)
Information Disclosure - Suspicious Comments	Software should not be released with known vulnerabilities or unfinished code, let alone leaving these highlighted by comments (Hoffman, 2024). Such security flaws should be rectified within security reviews that could an additional developer – outside of the development team – reviewing said code objectively (Hoffman, 2024).

Summary of conclusions

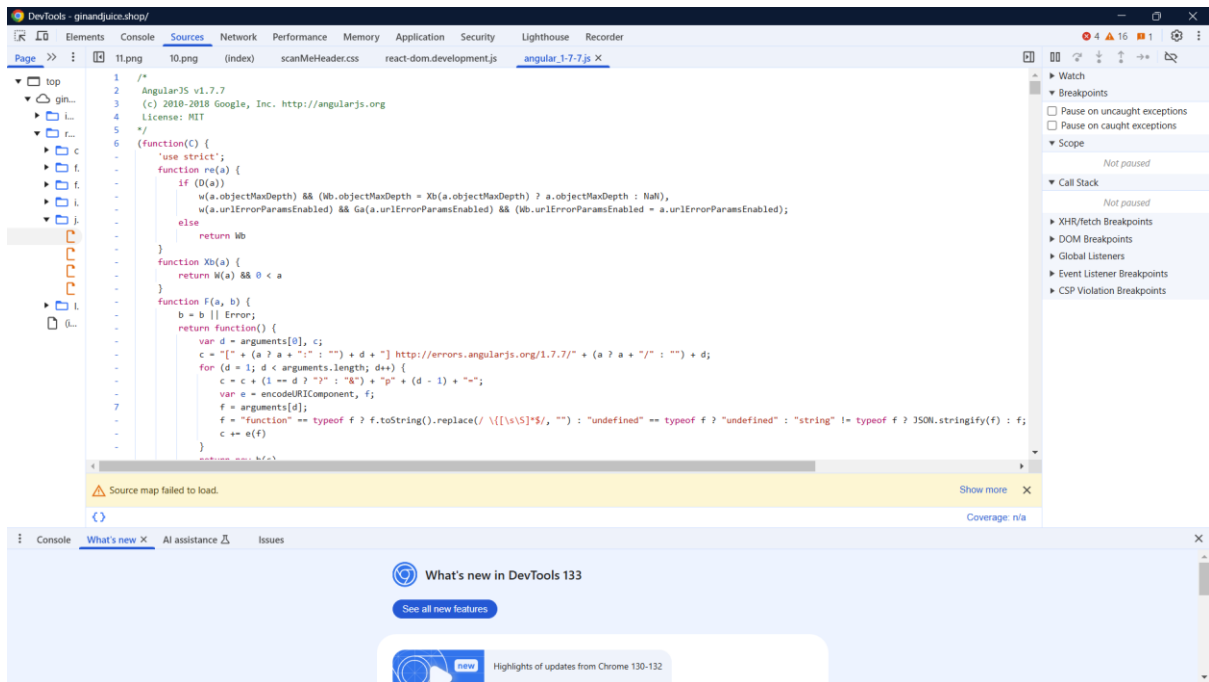
The security vulnerabilities listed in the previous section have the potential of costing the business millions of pounds worth of fines imposed as a result of confidentiality breaches through insecure data processing. The top 7 vulnerabilities can be quickly fixed with configuration tweaks. The SQL injection vulnerability can also lead to customer data leaks and so is also given a high priority for mitigation. This, and the remaining 2 vulnerabilities that could lead to a DOS attack, are easily avoidable and solvable with what would be deemed standard, security-conscious development processes: ensuring software components used are up-to-date; sanitising all user input data; and reviewing code comprehensively throughout the software development cycle (Hoffman, 2024; PCI Security Standards Council, 2024).

It is this report's recommendation that ginandjuice.shop is immediately taken offline while these mitigations are enacted; substantial fines and severe damage to company reputation are at stake, while longer term operational functionality (through the aforementioned ReDOS and DOS attacks) is also at risk. As previously stated, the site currently has partial compliance but should immediately enact the suggested mitigations to ensure full compliance.

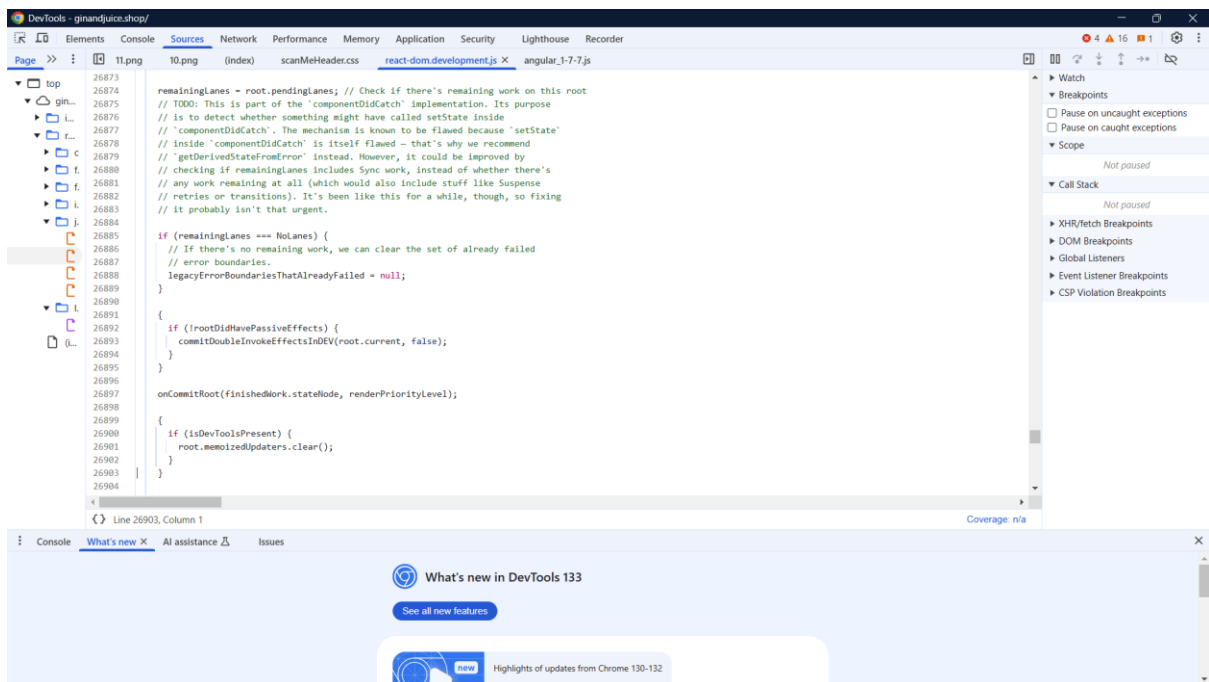
For future software changes, the company should consider employing SoCo – a semi-automated tool that checks for GDPR violations at the design stage, before suggesting mitigations to make software compliant (Ayala-Rivera, Portillo-Dominguez & Pasquale, 2024). Additionally, developers should ensure that software contains robust security logging, which involves a software configuration that helps to detect and prevent against security breaches, while enabling companies to stay GDPR-compliant (Holderer, 2022).

Appendices

Appendix 1: Evidence of out-of-date library comments (from manual test).



Appendix 2: Evidence of exposing comments (from manual test).



Appendix 3: Evidence for lack of Content Security Policy (from manual test).

2 / 18 requests

3.8 kB / 6.0 kB tr

Request Headers (23)

Headers

Payload

Preview

Response

Initiator

Timing

Cookies

Request URL:

Request Method:

Status Code:

Remote Address:

Referrer Policy:

https://ginandjuice.shop/catalog/cart

POST

302 Found

34.249.203.140:443

strict-origin-when-cross-origin

Response Headers

Content-Encoding:

Content-Length:

Date:

Location:

Set-Cookie:

Set-Cookie:

X-Backend:

X-Frame-Options:

gzip

0

Sat, 01 Mar 2025 20:40:52 GMT

/catalog/product?productid=2

AWSALB=uFCx+R06FbQNoUvkC4gkHUOmZBbU2rAe8NNSAsr8kIZDk
sIFPqT9YomZ/hAWNj9Sai90LvW0VcuW1DsaoX7exQIi0UbAO38gJUGYw
AY4KWk/1j9bUgM45R2; Expires=Sat, 08 Mar 2025 20:40:52 GMT;
Path=/
AWSALBCORS=uFCx+R06FbQNoUvkC4gkHUOmZBbU2rAe8NNSAsr8
kIZDksIFPqT9YomZ/hAWNj9Sai90LvW0VcuW1DsaoX7exQIi0UbAO38g
JUGYwAY4KWk/1j9bUgM45R2; Expires=Sat, 08 Mar 2025 20:40:52
GMT; Path=/; SameSite=None; Secure
51458aa7-0708-4c39-810d-a7e98b6c30e0
SAMEORIGIN

CONTENTS: 1 12000-page book.

HOW TO USE: Open the book. Close your eyes and flick through the pages until you feel like stopping. Spin your index finger round in the air and zoom it down to land somewhere on the page. Once landed choose the recipe closest to your fingertip.

CAUTION: Store in a cool dry place. Keep out of the way of children, especially those carrying felt tips!

London

CHECK STOCK

1

ADD TO CART

VIEW CART

Appendix 4: Evidence of Cookie No HttpOnly Flag, Cookie Without Secure Flag, Cookie with SameSite Attribute None, Cookie without SameSite Attribute (from manual test).

Response Cookies											
Name	Value	Domain	Path	Expires / Max...	Si...	HttpOnly	Secure	SameSite	Partitio...	Cross Si...	Priority
AWSALB	QLIOJVMPEYaa5//bkaW0QPjbs367tPGuHg6kSXJ6R...	ginandj...	/	2025-03-09T...	179						Medium
AWSALBCORS	QLIOJVMPEYaa5//bkaW0QPjbs367tPGuHg6kSXJ6R...	ginandj...	/	2025-03-09T...	205		✓	None			Medium

Appendix 5: Evidence for Anti-MIME-Sniffing header Content-Type-Options not set to 'nosniff' (from manual test).

ginandjuice.shop

General

Request URL:

Request Method:

Status Code:

Remote Address:

Referrer Policy:

https://ginandjuice.shop/

GET

200 OK

34.246.169.176:443

strict-origin-when-cross-origin

Response Headers

Content-Encoding:

Content-Length:

Content-Type:

Date:

Set-Cookie:

Set-Cookie:

X-Backend:

X-Frame-Options:

gzip

2130

text/html; charset=utf-8

Thu, 27 Feb 2025 08:49:57 GMT

AWSALB=CBYj8hd3lv6Rt0u+xc3T8CtsoyY1f16ChvIbqR9w6FoWXWnl2efwBoM0X8qWMpHeZAZpqZFLDjagncHLZQdvdmmipvtV54HG7HfBZ//ZixAe0nzMSH5Z27/imYag; Expires=Thu, 06 Mar 2025 08:49:57 GMT; Path=/
AWSALBCORS=CBYj8hd3lv6Rt0u+xc3T8CtsoyY1f16ChvIbqR9w6FoWXWnl2efwBoM0X8qWMpHeZAZpqZFLDjagncHLZQdvdmmipvtV54HG7HfBZ//ZixAe0nzMSH5Z27/imYag; Expires=Thu, 06 Mar 2025 08:49:57 GMT; Path=/; SameSite=None; Secure
343232c8-d5c6-4fb1-b9fb-14664064203f
SAMEORIGIN

Appendix 6: Evidence of SQL injection CryptoCat (2024) (from manual test).

ginandjuice.shop/catalog?searchTerm=&category=Juice%27UNION%20SELECT%20NULL,%20NULL,%20username,%20NULL,%20NULL,%20NULL,%20NULL,%20FRO...

CCNA

API tutorial

Bookmarks

University of Essex...

git-cheat-sheet-edu...

GitHub

Gemini

Course: Network Se...

Network Security

Usage: Activity - Op...

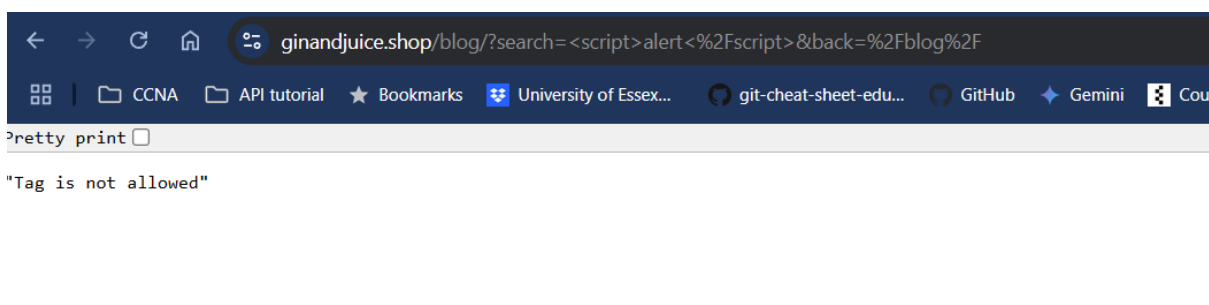
Customer data from database displayed in the html body as a result of a SQL injection performed in the URL.

Appendix 7: Evidence of input sanitisation, protecting against XSS

Input:



Output:



Appendix 8: Evidence of password-protected logging in

Password

LOG IN

Appendix 9: Evidence of secure cookies being used in request and response cookies, and HttpOnly flags being set for request cookies.

X

Headers

Payload

Preview

Response

Initiator

Timing

Cookies

Request Cookies

☐ show filtered out request cookies

Name	Value	Domain	Path	Expires / Max...	Si...	HttpOnly	Secure	SameS...	Part...	Cross Si...	Priority
AWSALB	qONMKkMQ8eVHc7cq//fFkttEHTfet9DjTkg8MLgJ...	ginandj...	/	2025-03-14T...	130						Medium
AWSALBCORS	qONMKkMQ8eVHc7cq//fFkttEHTfet9DjTkg8MLgJ...	ginandj...	/	2025-03-14T...	134		✓	None			Medium
TrackingId	eyJ0eXBlljoiY2hc3MilCjZyVWx1ZSI6Ilp6UTRmU2x1...	ginandj...	/	Session	70	✓	✓				Medium
category	Juice'UNION SELECT NULL, NULL, username, NULL...	ginandj...	/	Session	97	✓	✓				Medium
session	VgLx4697IWUP4SDXNjnx0SmmEGQpWh4i	ginandj...	/catalo...	Session	39	✓	✓	None			Medium
session	PEu1SnvPb3WzMIP7IMDpfnFpCYbOJO0n	ginandj...	/catalog	Session	39	✓	✓	None			Medium
session	aOkcxt01dRn5xshBLFL4GhjHc8XnUbj8	ginandj...	/	Session	39	✓	✓	None			Medium

Response Cookies

Name	Value	Domain	Path	Expires / Max...	Si...	HttpOnly	Secure	SameSite	Pa...	Cross Si...	Priority
AWSALB	z5URjX+pDJTveO+ZiZk0emKC8FFh92S5mJqE05Xlni...	ginandj...	/	2025-03-14T...	179						Medium
AWSALBCORS	z5URjX+pDJTveO+ZiZk0emKC8FFh92S5mJqE05Xlni...	ginandj...	/	2025-03-14T...	205		✓	None			Medium

Appendix 10:

```
tracert ginandjuice.shop Tracing route to ginandjuice.shop
[34.246.169.176] over a maximum of 30 hops: 1 2 ms 1 ms 1 ms
192.168.167.222 2 * * * Request timed out. 3 63 ms 40 ms 59 ms
172.20.37.225 4 * * * Request timed out. 5 * * * Request timed out. 6
53 ms 45 ms 68 ms 172.20.27.253 7 * * * Request timed out. 8 47 ms 72
ms 77 ms 172.16.87.238 9 * * * Request timed out. 10 * * * Request
timed out. 11 * * * Request timed out. 12 * * * Request timed out. 13
* * * Request timed out. 14 * * * Request timed out. 15 * * * Request
timed out. 16 * * * Request timed out. 17 * * * Request timed out. 18
* * * Request timed out. 19 * * * Request timed out. 20 * * * Request
timed out. 21 * * * Request timed out. 22 * * * Request timed out. 23
* * * Request timed out. 24 * * * Request timed out. 25 * * * Request
timed out. 26 * * * Request timed out. 27 * * * Request timed out. 28
* * * Request timed out. 29 * * * Request timed out. 30 * * * Request
timed out.
```

Appendix 11: NSlookup output

```
nslookup ginandjuice.shop
Server: UnKnown
Address: 192.168.167.222

Non-authoritative answer:
Name: ginandjuice.shop
Addresses: 34.249.203.140
          34.246.169.176
```

References

Ayala-Rivera, V., Portillo-Dominguez, A.O. and Pasquale, L. (2024) GDPR compliance via software evolution: Weaving security controls in software design. *The Journal of Systems & Software* 216, 112144: 1-22. DOI: <https://doi.org/10.1016/j.jss.2024.112144>

CheckMarx. (2025a) Content Security Policy (CSP) Header Not Set. Available from: <https://www.zaproxy.org/docs/alerts/10038-1/> [Accessed 02.03.25].

CheckMarx. (2025b) Vulnerable JS library. Available from: <https://www.zaproxy.org/docs/alerts/10003/> [Accessed 04.03.25].

CryptoCat. (2024) 1: SQL Injection (Union + Blind) - Gin and Juice Shop (Portswigger). Available from: <https://www.youtube.com/watch?v=4g2a-n4hjfY&t=1732s> [Accessed 26.02.25].

Data Protection Act. (2018) Available from: <https://www.legislation.gov.uk/ukpga/2018/12/contents/enacted> [Accessed 01.03.25].

Facebook Open Source. (2025) Error Boundaries. Available from: <https://legacy.reactjs.org/docs/error-boundaries.html?form=MG0AV3> [Accessed 05.03.25].

Hoffman, A. (2024) *Web Application Security*. 2nd ed. London: O'Reilly Media Inc.

Holderer, J. (2022) *Obstructions in Security-Aware Business Processes: Analysis, Detection, and Handling*. Wiesbaden: Springer Vieweg.

HTTP Working Group. (2016). Site Cookies draft-ietf-httpbis-cookie-same-site-00. Available from: <https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site> [accessed 03.03.25].

Loonycorn. (2017) *Web Security: Common Vulnerabilities And Their Mitigation*. 1st ed. Birmingham: Packt Publishing.

Microsoft. (2016) Reducing MIME type security risks. Available from: [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)) [accessed 01.03.25].

Mitre. (2024) CWE-546: Suspicious Comment. Available from: <https://cwe.mitre.org/data/definitions/546.html> [accessed 01.03.25].

Mozilla. (2025) X-XSS-Protection. Available from: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-XSS-Protection> [Accessed 03.03.25].

National Cyber Security Centre. (N.D.) Multi-factor authentication for your corporate online services. Available from: <https://www.ncsc.gov.uk/collection/mfa-for-your-corporate-online-services/mandating-strong-mfa-for-access-sensitive-data> [Accessed 07.03.25].

NIST. (2025) National Vulnerability Database. Available from: <https://nvd.nist.gov/> [Accessed 01.03.25].

OWASP. (2025a) HttpOnly. Available from: <https://owasp.org/www-community/HttpOnly> [Accessed 02.03.25].

OWASP. (2025b) WSTG - v4.1 Testing for Cookies Attributes. Available from: https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html [Accessed 02.03.25].

OWASP. (2025c) HTTP Strict Transport Security Cheat Sheet. Available from: https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html [Accessed 03.03.25].

PCI Security Standards Council (PCI DSS). (2024) *PCI DSS v4.0.1: Requirements and Testing Procedures*. Available from: https://www.pcisecuritystandards.org/document_library/ [Accessed 28.02.25].

Suorsa, M. & Helo, P (2024) Information security failures identified and measured – ISO/IEC 27001:2013 controls ranked based on GDPR penalty case analysis. *Information Security Journal: A Global Perspective* 33(3): 285-306. DOI: 10.1080/19393555.2023.2270984.